OT Security Risk Assessment according to IEC 62443-3-2

Fictional multi-wire drawing line “WDL-8” – machine supplier perspective

Portfolio work sample. The machine, its architecture, the data and all risk values are invented for demonstration. This document does not describe or assess any real product, customer or company.

Author: Sreeja Pillarisetty · Version 1.1 · October 2026

1. Purpose and scope

This assessment applies the zone-and-conduit risk assessment process of IEC 62443-3-2 to a connected machine as it would be delivered by a special-machine builder. The goal is to show how the methodology I used for automotive TARA (ISO/SAE 21434) transfers to industrial automation: identify assets and threats, rate risk, partition the system into zones and conduits, set target security levels (SL-T), and derive technical requirements from IEC 62443-3-3.

In scope: the machine’s control system, HMI, safety system and the two external connections (vendor remote service and customer MES). Out of scope: the customer’s plant network and the vendor’s own IT, which are treated as untrusted external zones.

2. System under consideration (ZCR 1)

WDL-8 is a fictional multi-wire drawing line that draws eight copper wires in parallel and anneals them inline. It runs 24/7 in the customer’s plant. An unplanned stop causes wire breaks and scrap, so **availability and process integrity matter more than confidentiality**, which is typical for OT.

Asset	Function	Why it matters
Machine PLC	Controls drives, tension, annealing current	Integrity of process; core of production
Drive controllers (VFDs)	Speed control of capstans and spoolers	Wrong setpoints break wire or damage tooling
Safety PLC + safety I/O	E-stop, light curtains, guard doors (PROFIsafe)	Protects people; must work independently
HMI industrial PC	Operation, recipes, alarms, data logger	Windows-based, largest attack surface
Remote-access gateway	On-demand VPN for vendor service	Only path from the Internet into the machine
OPC UA server	Order and recipe exchange with customer MES	Connects machine to customer network
Recipes & process parameters	Die sequences, speeds, annealing curves	Product quality and vendor know-how

Assumptions: the vendor is the product supplier/integrator, the customer is the asset owner and agrees the tolerable risk. Safety functions are designed according to the machinery safety standards and are not re-assessed here; this document only checks that security failures cannot defeat them.

3. Method

The work follows the zone and conduit requirements (ZCR) of IEC 62443-3-2:

Step	IEC 62443-3-2	Where in this document
ZCR 1	Identify the system under consideration	Section 2
ZCR 2	Initial (high-level) risk assessment	Section 4
ZCR 3	Partition into zones and conduits	Section 5
ZCR 4	Check if initial risk exceeds tolerable risk	Section 4 (all four exceed it)
ZCR 5	Detailed risk assessment per zone and conduit, SL-T	Sections 5 and 6
ZCR 6	Document cybersecurity requirements	Section 7
ZCR 7	Asset owner approval of residual risk	Section 9

Risk rating. Likelihood (L) and impact (I) are rated 1–5. Risk R = L × I. Tolerable risk agreed with the (fictional) customer: **R ≤ 6**. R 8–12 = medium (must be reduced or formally accepted), R ≥ 15 = high (must be reduced). Impact takes the worst of four categories: safety, production availability, product quality, confidentiality of know-how.

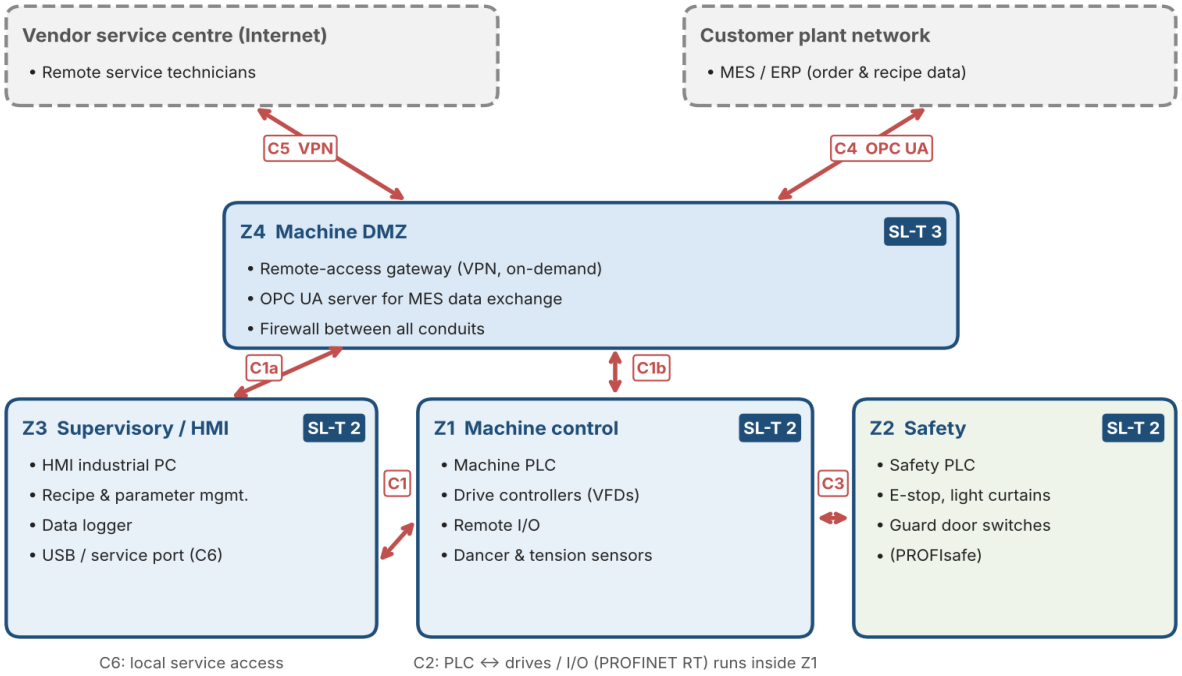
4. Initial risk assessment (ZCR 2 / ZCR 4)

Worst-case consequences if the machine had no security controls at all:

Consequence	Example	I	Exceeds tolerable?
Harm to people	Safety function disabled or bypassed via the network	5	Yes
Production stop	Ransomware on HMI, PLC stopped remotely; days of downtime	5	Yes
Quality loss	Manipulated tension or annealing parameters; scrap and claims	4	Yes
Loss of know-how	Recipes and PLC program copied by a competitor	3	Yes

Because every consequence exceeds the tolerable risk, a detailed assessment per zone is required.

5. Zones and conduits (ZCR 3) and target security levels



Zone	Contents	SL-T	Rationale
Z4 Machine DMZ	Remote-access gateway, OPC UA server, firewall	3	Only zone reachable from outside; attackers with IT skills and moderate resources are realistic
Z3 Supervisory / HMI	HMI PC, recipe management, data logger, service port	2	Not directly reachable from outside; main risk is malware and misuse by local users
Z1 Machine control	PLC, drives, remote I/O, sensors	2	Real-time; only reachable via Z3/Z4; legacy protocols without authentication
Z2 Safety	Safety PLC, e-stop, light curtains, guard switches	2	Separate zone so safety stays independent; write access only locally with password

Conduit	Connects	Protocol / medium	Key protection
C1 / C1a / C1b	Z3 ↔ Z1, Z4 ↔ Z3, Z4 ↔ Z1 (read only)	Ethernet, OPC UA	Firewall rules per direction, no routing from Z4 to Z2
C2	PLC ↔ drives / I/O (inside Z1)	PROFINET RT	Physically closed; managed switch, unused ports off
C3	Z1 ↔ Z2	PROFIsafe	Safety telegrams; safety config locked and checksummed
C4	Z4 ↔ customer network	OPC UA (SignAndEncrypt)	Certificates, allow-listed MES client only
C5	Z4 ↔ vendor service centre	VPN over Internet	On-demand, operator key switch, MFA, session logging
C6	Local service access to Z3	USB / Ethernet port	USB blocked by default; vendor laptops hardened

6. Detailed risk assessment (ZCR 5)

FR = foundational requirement of IEC 62443: FR1 identification and authentication, FR2 use control, FR3 system integrity, FR4 data confidentiality, FR5 restricted data flow, FR6 timely response to events, FR7 resource availability.

ID	Threat scenario	Where	L	I	R	Countermeasures (IEC 62443 FR)	Res. L×I	Res. R
T1	Attacker exploits an unpatched VPN vulnerability in the remote-access gateway and pivots to the PLC to stop or manipulate production	Z4, C5	4	5	20	Remote access only on demand via key switch at the machine (FR2); MFA and individual accounts (FR1); gateway hardening and SBOM-based patching (FR3); session logging (FR6); no direct path Z4→Z2 (FR5)	1×4	4
T2	Malware (e.g. ransomware) brought in via USB stick on the HMI PC; HMI unusable, line stops	Z3, C6	4	4	16	USB mass storage disabled, approved devices only (FR2); application allow-listing and read-only OS image (FR3); offline backup and tested restore (FR7)	2×3	6
T3	Operator or contractor changes process parameters with a shared HMI password; wire breaks and quality defects	Z3	4	3	12	Individual user accounts with roles operator/shift lead/service (FR1, FR2); audit log of parameter changes (FR6); plausibility limits in the PLC (FR3)	2×3	6
T4	Infected service laptop uploads a modified PLC program	Z1, C6	3	5	15	PLC write protection with password, program change detection via checksum and alarm on HMI (FR3); laptop hardening checklist before every service visit (FR2); change log (FR6)	1×5	5
T5	Broadcast storm or network scan from the customer network disturbs PROFINET real-time traffic; machine stops	C4, Z1	3	4	12	Firewall in Z4 with rate limiting, no routing from customer network to Z1 (FR5, FR7); managed switches with storm control (FR7)	1×4	4
T6	Known vulnerability in a third-party component (OPC UA stack, HMI OS libraries) is exploited	Z4, Z3	4	4	16	SBOM per machine variant; CVE monitoring and VEX assessment in the machine context; patch process with customer (FR3, see Section 8)	2×4	8
T7	Order and recipe data between MES and machine is read or altered in transit	C4	3	3	9	OPC UA SignAndEncrypt with certificates; allow-listed client (FR3, FR4)	1×3	3
T8	Safety configuration is changed over the network to disable a light curtain	Z2, C3	2	5	10	Safety PLC in own zone, no write access from Z3/Z4 (FR5); safety password and signature check; changes only locally (FR1, FR3)	1×5	5
T9	Drive parameters are changed via unauthenticated PROFINET access	Z1, C2	2	4	8	C2 physically closed and not routable (FR5); drive parameter lock; unused switch ports disabled (FR7)	1×4	4
T10	Vendor technician changes settings during a remote service session; the machine fails afterwards. Without individual accounts and session logs nobody can prove who changed what, the cause is not found, and customer and vendor dispute liability	Z4, C5, Z1	3	4	12	Configuration check against the approved baseline after every service session before production restarts (FR3); logging of every remote session: who, when, what changed (FR6); individual accounts with MFA (FR1)	1×3	3

Result: nine of ten threats reach the tolerable level (R ≤ 6) after countermeasures. T6 remains at R = 8 because third-party vulnerabilities keep appearing during the machine's lifetime. This residual risk cannot be designed away; it is handled by an ongoing process (Section 8) and presented to the asset owner for acceptance (Section 9).

Note on T10: logging and the baseline check mainly lower the likelihood (wrong changes are caught before production restarts, and people act more carefully when actions are traceable). They also lower the impact, because the cause is found quickly and the approved settings can be restored.

7. Derived security requirements (ZCR 6)

Requirements are mapped to the system requirements (SR) of IEC 62443-3-3 so they can be checked against component capabilities from IEC 62443-4-2 during supplier selection.

Req.	Requirement	IEC 62443-3-3	Zones	Threats
R1	Unique user accounts on HMI and gateway; no shared passwords	SR 1.1	Z3, Z4	T1, T3, T10
R2	Remote access only after explicit approval at the machine (key switch)	SR 1.13	Z4	T1
R3	Role-based permissions: operator, shift lead, service	SR 2.1	Z3	T3
R4	Block USB mass storage; allow only approved devices	SR 2.3	Z3	T2, T4
R5	Log logins, parameter changes and remote sessions	SR 2.8	Z3, Z4	T1, T3, T4, T10
R6	Protect integrity of OPC UA and remote-access traffic	SR 3.1	C4, C5	T1, T7

Req.	Requirement	IEC 62443-3-3	Zones	Threats
R7	Malware protection through application allow-listing on HMI	SR 3.2	Z3	T2
R8	Detect changes to PLC and safety program (checksum, alarm)	SR 3.4	Z1, Z2	T4, T8
R9	Encrypt recipe and order data on C4	SR 4.1	C4	T7
R10	Segment Z1–Z4; firewall at every zone boundary; deny by default	SR 5.1, SR 5.2	all	T1, T5, T8, T9
R11	Rate limiting and storm control towards real-time network	SR 7.1	Z1, Z4	T5
R12	Offline backup of HMI and PLC with documented restore test	SR 7.3	Z1, Z3	T2
R13	Disable unused services and switch ports	SR 7.7	all	T6, T9
R14	Compare machine configuration with the approved baseline after every service session, before production restarts	SR 3.4	Z1, Z3	T10

8. Vulnerability and patch management during operation

- **SBOM per machine variant** (CycloneDX) covering HMI OS, OPC UA stack, gateway firmware and PLC firmware versions.
- **Monitoring:** new CVEs are matched against the SBOM. Each finding is assessed in the machine context: is the vulnerable function used, and is it reachable from a conduit? The decision is documented as VEX (affected / not affected / fixed).
- **Patch planning:** patches are tested on a reference machine first, then scheduled with the customer in a planned production stop. Every patch has a documented rollback (image backup).
- **Urgent cases:** if a vulnerability is actively exploited and reachable, a temporary measure is applied immediately (e.g. remote access disabled at the key switch) until the patch is installed.

A working example of the SBOM → scan → triage → VEX workflow is in my repository **github.com/Sreejapillarisetty11/Vuln-handling-demo**.

9. Residual risk and approval (ZCR 7)

Threat	Residual risk	Proposed handling	Approval
T6	R = 8 (medium)	Accept on condition: monthly CVE review against SBOM, critical reachable vulnerabilities mitigated within 30 days, yearly review of this assessment	Asset owner (customer) – pending
T1–T5, T7–T10	R ≤ 6	Within tolerable risk; verify countermeasures at factory acceptance test	Supplier

Regulatory note. Connected machines are increasingly covered by regulation: the EU Machinery Regulation (EU) 2023/1230 applies from January 2027 and requires protection against corruption, and the EU Cyber Resilience Act will apply to products with digital elements such as the HMI and gateway. A documented risk assessment like this one is a basis for both.

10. Limitations

- Fictional system and invented ratings; a real assessment needs the customer's network data, threat intelligence and an agreed risk matrix.
- Likelihood is rated qualitatively; a real project would justify it with attack paths and capability assumptions per SL.
- Component-level checks against IEC 62443-4-2 (e.g. whether the chosen PLC supports the required capabilities) are not included.